

ΠΟΛΙΤΙΚΗ ΕΛΕΓΧΟΥ ΠΡΟΣΒΑΣΗΣ & ΡΟΛΩΝ (ACCESS CONTROL POLICY)

Έκδοση: 1η έκδοση

Ημερομηνία: 01/02/2026

1. Σκοπός

Η παρούσα πολιτική ορίζει τις αρχές και διαδικασίες για τη διαχείριση της πρόσβασης στα πληροφοριακά συστήματα του οργανισμού, σύμφωνα με τις απαιτήσεις της NIS2. Στοχεύει στη διασφάλιση της εμπιστευτικότητας, της ακεραιότητας και της διαθεσιμότητας των πληροφοριών και στην αποτροπή μη εξουσιοδοτημένης πρόσβασης, διαρροής ή αλλοίωσης των ευαίσθητων δεδομένων.

2. Πεδίο Εφαρμογής

Εφαρμόζεται σε

Χρήστες: Ιατρικό προσωπικό, Γραμματεία

Συστήματα / Εφαρμογές: RIS, PACS, H/Y, MRI Workstation

Υποδομές / Δίκτυα: Εσωτερικό δίκτυο, Switches, Firewall, VPN, Servers, Backup

3. Αρχές Ελέγχου Πρόσβασης

Ελάχιστο απαιτούμενο δικαίωμα (Least Privilege): Η πρόσβαση στα συστήματα παρέχεται αποκλειστικά στο βαθμό που απαιτείται. Ενδεικτικά, μόνο το εξουσιοδοτημένο ιατρικό προσωπικό έχει πρόσβαση σε ιατρικές εξετάσεις και απεικονιστικά δεδομένα μέσω του συστήματος PACS.

MFA για ευαίσθητα συστήματα: ☐ Ναι ☐ Όχι

Η πρόσβαση σε ευαίσθητα συστήματα που περιέχουν προσωπικά και ιατρικά δεδομένα, όπως το RIS και το PACS πρέπει να περιέχει επιπρόσθετη ασφάλεια, η οποία μειώνει τον κίνδυνο αλλοίωσης, παραβίασης και διαρροής ευαίσθητων δεδομένων. Η χρήση MFA για την αυθεντικοποίηση των χρηστών του εσωτερικού δικτύου αλλά και των χρηστών του εξωτερικού δικτύου, που συνδέονται στα συστήματα μέσω VPN (εξωτερικοί γιατροί, πάροχος MRI Scanner) είναι απαραίτητη για την ασφαλή και εξουσιοδοτημένη πρόσβαση στο σύστημα.

4. Διαδικασία Δημιουργίας / Τροποποίησης / Απενεργοποίησης Λογαριασμών

Αίτηση πρόσβασης: Ηλεκτρονικό αίτημα πρόσβασης στα προβλεπόμενα συστήματα.

Έγκριση από: Διευθυντή ακτινολογικού κέντρου, Υπεύθυνο ασφαλείας συστημάτων πληροφορικής και επικοινωνιών (ΥΑΣΠΕ).

Χρόνος απενεργοποίησης μετά από αποχώρηση: Η απενεργοποίηση των λογαριασμών θα πρέπει να γίνεται άμεσα, εντός 24 ωρών μετά την αποχώρηση του εργαζομένου.

Ετήσια αναθεώρηση ρόλων: ☐ Ναι / ☐ Όχι – **Συχνότητα:** Ανά έτος

5. Έλεγχος Πρόσβασης σε Δεδομένα

Επίπεδα πρόσβασης:

- Πρόσβαση σε οργανωτικά δεδομένα και στοιχεία ασθενή
- Πρόσβαση σε προσωπικά στοιχεία ασθενή και σε ιατρικές εξετάσεις και γνωματεύσεις

Διαδικασία έγκρισης πρόσβασης σε ευαίσθητα δεδομένα: Αφού καθοριστεί το επίπεδο πρόσβασης δεδομένων από τον διευθυντή και τον υπεύθυνο ασφαλείας, εγκρίνεται το αντίστοιχο ηλεκτρονικό αίτημα και παραχωρείται λογαριασμός με τα ανάλογα δικαιώματα.

6. Καταγραφή & Παρακολούθηση

Τι καταγράφεται (logs): Καταγραφή πληροφοριών σχετικά με τα άτομα που αποκτούν πρόσβαση στα συστήματα (IP, λογαριασμός), πληροφορίες του γεγονότος (ημερομηνία, ώρα, διάρκεια) αλλά και σε ποια στοιχεία ή σελίδες αποκτήθηκε πρόσβαση.

Χρόνος διατήρησης: 1 έτος

7. Εξαιρέσεις / Ειδικές Περιπτώσεις

Σε ειδικές περιπτώσεις εκτάκτου ανάγκης, που επηρεάζεται η υγεία του ασθενή ή η λειτουργία του οργανισμού, μπορεί να παραχωρηθεί προσωρινή πρόσβαση σε συστήματα ή δεδομένα που δεν εμπίπτουν στα δικαιώματα του χρήστη. Η εξαίρεση αυτή εγκρίνεται από τον διευθυντή του οργανισμού και ισχύει για περιορισμένο χρονικό διάστημα. Το δικαίωμα αυτό ανακαλείται αμέσως μετά το πέρας του περιστατικού.

ΠΟΛΙΤΙΚΗ ΔΙΑΧΕΙΡΙΣΗΣ ΕΝΗΜΕΡΩΣΕΩΝ (PATCH MANAGEMENT)

Έκδοση: 1η έκδοση

Ημερομηνία: 01/02/2026

1. Σκοπός

Η παρούσα πολιτική εξασφαλίζει ότι όλα τα πληροφοριακά συστήματα του οργανισμού ενημερώνονται εγκαίρως για την αντιμετώπιση ευπαθειών. Ειδικότερα, περιγράφεται η διαδικασία και ο έλεγχος εγκατάστασης μιας εφαρμογής στο σύστημα του οργανισμού με ασφάλεια, διατηρώντας την εμπιστευτικότητα, ακεραιότητα και διαθεσιμότητα των πληροφοριών και εξασφαλίζοντας την προστασία τους από γνωστές ευπάθειες.

2. Πεδίο Εφαρμογής

Servers: RIS, PACS

Υπολογιστές: Η/Υ Ιατρού, Η/Υ Ακτινολόγου, Η/Υ Τεχνικού Ακτινολόγου, Η/Υ Γραμματείας

Εξοπλισμός δικτύου: Switches και σχετικές δικτυακές συσκευές

3. Συχνότητα Ενημερώσεων

Κρίσιμες ενημερώσεις: Εντός 12 ωρών

Ασφαλείας: ☐ Εβδομαδιαία ☐ Μηνιαία ☐ Άλλη:

Λειτουργικού συστήματος: Ετήσια ή σύμφωνα με τις οδηγίες του κατασκευαστή

Εφαρμογών: Ετήσια ή όταν διατεθεί κρίσιμη ενημέρωση

4. Διαδικασία Εντοπισμού Ευπαθειών

Εργαλεία που χρησιμοποιούνται:

- Ανακοινώσεις κατασκευαστών λειτουργικών συστημάτων και εφαρμογών
- Ενημερώσεις προμηθευτών ιατρικών συστημάτων (RIS/PACS)
- Παρακολούθηση δικτύου και περιστατικών ασφαλείας

Πηγή ενημερώσεων: Εγκεκριμένοι και πιστοποιημένοι πάροχοι λογισμικού και υποστήριξης

5. Διαδικασία Εφαρμογής

Έλεγχος συμβατότητας: Αξιολόγηση συμβατότητας της ενημέρωσης με το υπάρχον δίκτυο, τις υπηρεσίες και τον ιατρικό εξοπλισμό.

Δοκιμή σε περιβάλλον staging: Εάν είναι εφικτό, πραγματοποιείται δοκιμαστική εγκατάσταση σε προσομοιωμένο περιβάλλον, με στόχο την ανίχνευση σφαλμάτων.

Εγκατάσταση: Μετά την επιτυχή ολοκλήρωση των δοκιμών, πραγματοποιείται ενημέρωση της εφαρμογής στο σύστημα του οργανισμού, εκτός των ωρών αιχμής, εάν αυτό είναι δυνατό.

Τεκμηρίωση: Καταγράφονται σχετικές πληροφορίες, όπως ημερομηνία ενημέρωσης, σύστημα ή συσκευή, αναγνωριστικό της ενημέρωσης, υπεύθυνος διαδικασίας ενημέρωσης και παρατηρήσεις ή προβλήματα.

Rollback plan: Πριν από κάθε ενημέρωση, λαμβάνεται ένα αντίγραφο ασφαλείας, ώστε σε περίπτωση αποτυχίας, το σύστημα να μπορεί να επανέλθει άμεσα στην προηγούμενη κατάσταση.

Λεπτομέρειες: Σε κάθε ενημέρωση καταγράφονται οι εξής πληροφορίες: περιγραφή και κατηγορία ενημέρωσης, έκδοση του λογισμικού, ημερομηνία και ώρα εγκατάστασης, υπεύθυνος εγκατάστασης, αποτέλεσμα εγκατάστασης, προβλήματα και διορθωτικές ενέργειες.

6. Καταγραφή

Σημειώνονται όλα τα patches στο: ☐ Έγγραφο ☐ Excel ☐ Άλλο

ΠΟΛΙΤΙΚΗ ΓΙΑ DATA-AT-REST ΑΣΦΑΛΕΙΑ (ΕΜΠΙΣΤΕΥΤΙΚΟΤΗΤΑ, ΑΚΕΡΑΙΟΤΗΤΑ, ΔΙΑΘΕΣΙΜΟΤΗΤΑ)

Έκδοση: 1η έκδοση

Ημερομηνία: 01/02/2026

1. Σκοπός

Προστασία δεδομένων που αποθηκεύονται σε servers, βάσεις δεδομένων, endpoints, φορητά μέσα και cloud. Στόχος της παρούσας πολιτικής είναι η διασφάλιση της εμπιστευτικότητας των δεδομένων, η διατήρηση της ακεραιότητας και η διαθεσιμότητα των δεδομένων κάθε χρονική στιγμή.

2. Πεδίο Εφαρμογής

Συστήματα: RIS, PACS

Βάσεις δεδομένων: RIS, PACS, Απομακρυσμένο Backup

Αρχεία / Backups: Αρχεία αποθηκευμένα σε τοπικούς ή απομακρυσμένους Η/Υ, απομακρυσμένο αντίγραφο ασφαλείας

3. Εμπιστευτικότητα (Confidentiality)

Κρυπτογράφηση σε αποθήκευση (AES256/άλλο): ☐ Ναι / ☐ Όχι

Κρυπτογράφηση των δεδομένων με τον αλγόριθμο AES256.

Key management: Τα κλειδιά κρυπτογράφησης δημιουργούνται, αποθηκεύονται και ενημερώνονται με ασφαλή τρόπο.

Πρόσβαση περιορισμένη σε χρήστες: Η πρόσβαση στα δεδομένα διατίθεται σε εξουσιοδοτημένους χρήστες. Κάθε χρήστης διαθέτει συγκεκριμένα δικαιώματα σύμφωνα με την πολιτική ΠΟΛΙΤΙΚΗ ΕΛΕΓΧΟΥ ΠΡΟΣΒΑΣΗΣ & ΡΟΛΩΝ.

4. Ακεραιότητα (Integrity)

Hashing / Checksum: Χρήση αλγορίθμου SHA-256 για τον έλεγχο της ακεραιότητας των αρχείων και αντιγράφων ασφαλείας.

Logging αλλαγών αρχείων: ☐ Ναι / ☐ Όχι

Παρακολούθηση μη εξουσιοδοτημένων αλλαγών: Πλήρης παρακολούθηση μέσω συστημάτων ελέγχου ακεραιότητας και ειδοποιήσεων.

5. Διαθεσιμότητα (Availability)

Backups: ☐ Ημερήσιο ☐ Εβδομαδιαίο ☐ Άλλο:

Redundancy: Ύπαρξη απομακρυσμένου backup για προστασία των δεδομένων σε περίπτωση τοπικής καταστροφής.

RTO: 12 ώρες

RPO: 4 ώρες

ΠΟΛΙΤΙΚΗ ΓΙΑ DATA-IN-TRANSIT ΑΣΦΑΛΕΙΑ

Έκδοση: 1η έκδοση

Ημερομηνία: 01/02/2026

1. Σκοπός

Διασφάλιση ότι όλα τα δεδομένα κατά τη μεταφορά είναι κρυπτογραφημένα και προστατευμένα από μη εξουσιοδοτημένη πρόσβαση, υποκλοπή ή αλλοίωση. Στόχος της παρούσας πολιτικής είναι η μείωση του κινδύνου διαρροής των δεδομένων, διατηρώντας την εμπιστευτικότητα και ακεραιότητα των δεδομένων.

2. Τεχνολογίες Κρυπτογράφησης

TLS έκδοση: TLS 1.2

VPN: ☐ IPsec ☐ SSL VPN ☐ WireGuard ☐ Άλλο

Εσωτερική κρυπτογράφηση υπηρεσιών (service-to-service): Χρήση TLS για επικοινωνία μεταξύ εσωτερικών συστημάτων.

3. Σημεία Μεταφοράς Δεδομένων

Εσωτερικό δίκτυο: Μεταφορά δεδομένων μέσω κρυπτογραφημένων καναλιών, αν είναι εφικτό.

Cloud: Επικοινωνία με cloud υπηρεσίες μέσω κρυπτογραφημένων συνδέσεων.

API / Integrations: Τα APIs χρησιμοποιούν HTTPS με TLS και μηχανισμούς αυθεντικοποίησης (tokens ή certificates).

4. Έλεγχος Ταυτότητας & Πρόσβασης

MFA για απομακρυσμένη πρόσβαση: ☐ Ναι ☐ Όχι

Certificate-based authentication: ☐ Ναι ☐ Όχι

5. Παρακολούθηση

IDS/IPS: Χρήση συστημάτων ανίχνευσης παραβιάσεων για την παρακολούθηση ύποπτων ή κακόβουλων ενεργειών.

TLS inspection (αν εφαρμόζεται): Εάν είναι εφικτό εφαρμόζεται, με σεβασμό στα προσωπικά δεδομένα.

ΠΟΛΙΤΙΚΗ ΚΑΤΑΤΜΗΣΗΣ ΔΙΚΤΥΟΥ & ΑΣΦΑΛΟΥΣ ΠΡΟΣΒΑΣΗΣ ΕΦΟΔΙΑΣΤΙΚΗΣ ΑΛΥΣΙΔΑΣ

Έκδοση: 1η έκδοση

Ημερομηνία: 01/02/2026

1. Σκοπός

Ορισμός των μέτρων για δικτυακό διαχωρισμό και για ασφαλή διασύνδεση τρίτων (προμηθευτών, συνεργατών). Στόχος είναι η μείωση κινδύνου από απειλές της εφοδιαστικής αλυσίδας και η προστασία κρίσιμων συστημάτων και δεδομένων.

2. Κατάτμηση Δικτύου

Τμήματα του δικτύου (VLANs / Zones): Οι κύριες ζώνες του δικτύου αποτελούνται από την εσωτερική ζώνη (RIS, PACS, servers), διοικητική ζώνη (γραμματεία), ζώνη ιατρικού εξοπλισμού (MRI, MRI workstation), ζώνη απομακρυσμένης πρόσβασης (VPN), ζώνη ελεγχόμενης ζώνης για πρόσβαση στο διαδίκτυο.

DMZ: Συστήματα που απαιτούν πρόσβαση από το διαδίκτυο ή τρίτους, χωρίς άμεση πρόσβαση στα εσωτερικά δίκτυα.

Κανόνες επικοινωνίας μεταξύ δικτυακών ζωνών: Η επικοινωνία μεταξύ ζωνών επιτρέπεται μόνο όταν είναι απαραίτητη. Η κίνηση ελέγχεται μέσω firewall και καταγράφεται.

3. Firewall & Access Rules

Firewall vendor: Εμπορικό firewall εγκεκριμένο από τον οργανισμό.

Policy set: Χρήση πολιτικής “deny by default” με ρητή έγκριση μόνο των απαραίτητων θυρών, πρωτοκόλλων και IPs.

Change control διαδικασία: Αλλαγές στους κανόνες firewall πραγματοποιούνται κατόπιν αιτήματος και έγκρισης από τον ΥΑΣΠΕ. Οι αλλαγές καταγράφονται στο σύστημα αλλαγών.

4. Ασφαλής Πρόσβαση Προμηθευτών

Προμηθευτές που χρειάζονται πρόσβαση: Προμηθευτές συστημάτων (RIS/PACS) και υποστήριξης συστημάτων.

Τύποι πρόσβασης (VPN, API, Portal): VPN, API με αυθεντικοποίηση, ελεγχόμενο Web Portal.

Έλεγχοι ασφαλείας: Πρόσβαση παρέχεται μόνο για συγκεκριμένο σκοπό και περιορισμένο χρονικό διάστημα.

MFA: ☐ Ναι / ☐ Όχι

Περιορισμός ωραρίου πρόσβασης: ☐ Ναι / ☐ Όχι

Monitor logs τρίτων: Οι ενέργειες τρίτων χρηστών καταγράφονται και παρακολουθούνται. Τα logs διατηρούνται σύμφωνα με την πολιτική καταγραφής συμβάντων.